ASSIGNMENT REPORT

Social Engineering & Phishing Campaign Simulation

Phishing Risk Assessment and Executive Summary

1. Executive Summary

A controlled phishing simulation intended to assess how users respond to a simulated social-engineering message and whether existing awareness and technical controls reduce the likelihood of unsafe actions.

2. Objective and Scope

2.1 Objective

The objective is to measure susceptibility to a controlled phishing message and evaluate the effectiveness of relevant security-awareness and technical controls. The assessment considers the campaign lifecycle, user interaction metrics, risk interpretation and recommendations for management.

2.2 Authorised scope

Item	Scope
Assessment type	Controlled, internal, benign phishing simulation
Framework	GoPhish
Operator role	GRC analyst
Target	c11.cgrce2617594@icdfa.edu.ng

3. Results and Risk Metrics

Metric	Illustrative result	Calculation	Rate	Risk interpretation	Control implication to investigate
Emails opened	18 of 20	18 / 20 x 100	90%	High engagement with the simulated message.	Review awareness of unexpected or urgent messages. Open events alone do not prove that a user was deceived.
Links clicked	15 of 20	15 / 20 x 100	75%	High level of interaction with the simulated link.	Reinforce link inspection and suspicious-message reporting. Review email filtering, but do not infer filter failure from clicks alone.

Data submitted	10 of 20	10 / 20 x 100	50%	Critical human-risk indicator in the illustrative scenario.	Strengthen authentication controls and targeted training. Never use real credentials in the lab.

Additional funnel ratios, calculated from the same illustrative dataset:

- Clicks as a proportion of opens: 15 / 18 x 100 = **83.3%**.
- Submissions as a proportion of clicks: 10 / 15 x 100 = **66.7%**

3.3 Risk interpretation

Human susceptibility: The illustrative 90% open rate shows strong engagement with the simulated message. An open event can be affected by email client behaviour and should not be treated by itself as proof that a person trusted the message.

Unsafe link interaction: The illustrative 75% click rate points to a need to reinforce checking of unexpected links, sender identity and message context. The campaign does not, by itself, establish whether email filtering was bypassed or whether a particular technical gateway failed.

Potential credential exposure: The illustrative 50% data-submission rate is the most serious result. In a real attack, submission of valid credentials could create an account-compromise path. This lab must use synthetic values only and cannot establish that real credentials were compromised.

4. Control Assessment

Control area	Assessment from the scenario	Recommended action	Suggested owner
Security awareness	The illustrative interaction rates suggest that awareness may not be sufficiently effective. Actual effectiveness must be assessed using measured campaign results and training history.	Replace one-off awareness activity with short, recurring and role-targeted learning. Include examples of urgency, password-expiry and impersonation themes.	HR / Security Awareness Lead
Email security	Click activity warrants a review of mail filtering and reporting controls, but does not prove a filtering failure.	Review email security configuration, message authentication, URL inspection and user-reported phishing workflow.	IT / Email Security Administrator
Authentication	A high submission rate makes credential protection a priority.	Accelerate MFA across critical systems; prioritise phishing-resistant MFA where supported.	IAM / IT Security Lead
Reporting process	A simulation should measure not only clicks but also whether users report suspicious messages. The brief does not provide a report-rate metric.	Add a simple reporting mechanism and include it in onboarding and the AUP. Measure time-to-report and report rate in future exercises.	SOC / Service Desk / HR

Governance	Repeatable tests provide evidence for management decisions and training investment.	Integrate authorised simulations into onboarding and run them quarterly, subject to approvals and scope controls.	GRC / CISO

5. Recommendations and Action Plan

Priority	Recommendation	Expected risk-reduction outcome	Proposed measure
1 - Immediate	Expand MFA coverage across critical systems and review exceptions.	Stolen passwords alone are less likely to provide access. MFA is a risk-reduction layer, not a substitute for secure account recovery and access controls.	MFA coverage by critical application; number and age of exceptions.
2 - High	Introduce continuous, engaging and targeted awareness training rather than relying only on annual compliance videos.	Users are more likely to recognise and report suspicious messages.	Training completion and repeat-simulation trend by role or department.
3 - High	Include phishing guidance in onboarding and conduct authorised quarterly simulations.	New and existing staff receive repeated practice and the organisation can track control improvement.	Click rate, test-data submission rate and report rate per campaign.
4 - Medium	Review and update the AUP to define how suspicious messages must be identified and reported.	Expectations and responsibilities are clear.	AUP approval date; reporting procedure published; staff acknowledgement rate.
5 - Medium	Review email filtering and incident-reporting workflows in light of campaign observations.	Potential technical and process weaknesses are investigated rather than assumed.	Review findings, remediation owners and closure dates.

6. Management Decision Requested

Management is requested to:

1. Sponsor MFA coverage improvements for critical systems.
2. Approve a continuous phishing-awareness programme and quarterly, authorised simulations.
3. Assign owners and target dates for the AUP and suspicious-message reporting updates.
4. Require future campaign reporting to include click, synthetic-submission and report rates, sample size, scope and evidence references.

7. Conclusion

A controlled phishing simulation provides a practical way to assess the human-risk component of information security. The illustrative dataset highlights the importance of reducing unsafe link interaction and protecting accounts against credential theft. The value of the exercise depends on accurate evidence, clear scope, safe handling of test data and management actions that can be measured over time.